



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

L3: POST AUDIT ACTIVITIES

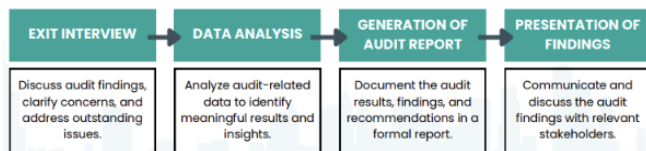
TOPIC OVERVIEW

- A. INTRODUCTION: WHAT ARE POST-AUDIT ACTIVITIES?
- B. EXIT INTERVIEW
 - a. Participants In The Exit Interview
 - b. Purpose Of The Exit Interview
 - c. How Auditors Use The Exit Interview
 - d. What To Prepare Before The Auditors Leave
 - e. Advantages And Limitations
- C. DATA ANALYSIS
 - a. The Five Steps To Get You Started With Data Analysis
- D. GENERATION OF AUDIT REPORTS
 - a. Audit Report Format
- E. PRESENTATION FINDINGS
 - a. Purpose Of The Presentation Of Findings
 - b. How Findings Are Presented
 - c. What To Prepare Before The Presentation
 - d. Advantages And Limitations

A INTRODUCTION: WHAT ARE POST-AUDIT ACTIVITIES?

WHAT ARE POST-AUDIT ACTIVITIES?

- Post-audit activities are the activities performed **after the audit has been conducted** to **review, analyze, document, and communicate the results of the audit**.
 - They help the organization **understand the audit findings, address identified issues, and determine appropriate actions** for improvement.



B EXIT INTERVIEW

EXIT INTERVIEW

- An exit interview, also called an **exit or closing meeting**, is a meeting **held at the**

conclusion of audit fieldwork, when necessary, to **discuss audit findings, resolve questions or concerns**, and **address outstanding issues** before the final audit report is released.

OBJECTIVES

- **Clarify**
 - **Resolve questions or concerns** about the audit results.
- **Discuss**
 - **Address** other issues or outstanding matters before finalization.
- **Prepare**
 - Allow the audit client to **provide responses and comments** before the final report is issued.

WHERE DOES IT FIT?

- Audit Fieldwork
- Exit Interview
- Management Responses & Comments
- Draft Report Review
- Final Audit Report

B1 PARTICIPANTS IN THE EXIT INTERVIEW

AUDIT TEAM

- **Conducts** and **facilitates** the audit
- **Presents** and **explains** the audit results
- e.g., Lead Auditor / Audit Team Leader
- **Purpose of Their Participation**
 - **Present and explain the audit findings**, facilitate the discussion, and address questions or concerns about the audit

MANAGEMENT OF THE AUDITED ENTITY

- e.g., Dean, Chairperson, Director, or managers responsible for the audited functions
- **Purpose of Their Participation**
 - **Review the findings**, provide explanations or additional context, and respond to issues identified during the audit

OTHER PARTICIPANTS

- Other individuals invited by the audit client
- **Purpose of Their Participation**
 - **Provide** relevant information, **clarification**, or perspective regarding the audited processes or findings.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

B2 PURPOSE OF THE EXIT INTERVIEW

PURPOSE OF THE EXIT INTERVIEW

- The exit interview gives the auditor and the audited entity an opportunity to **discuss findings, clarify concerns, and establish a common understanding before the report is finalized.**

PURPOSE OF THE EXIT INTERVIEW

- **Clarify Findings**
 - **Discuss audit findings and resolve misunderstandings** about the audit process, evidence, or conclusions.
- **Obtain Management Response**
 - Allow management to provide **explanations, additional context, and responses** to identified issues.
- **Discuss Improvements**
 - **Discuss recommendations,** corrective actions, responsibilities, and timelines.
- **Identify Risks & Weaknesses**
 - Provide an **objective view of weaknesses** and areas requiring attention.

B3 HOW AUDITORS USE THE EXIT INTERVIEW

HOW AUDITORS USE THE EXIT INTERVIEW

- During the exit interview, auditors **use the meeting to identify and discuss missing or outstanding information** that may still be needed before the audit is completed.

TWO KEY QUESTIONS

- **WHO?**
 - Who is responsible for **providing the missing information?**
- **WHEN?**
 - When can the auditor expect the **information to be provided?**

EXAMPLE

- **IT department hasn't submitted its latest access control review or user-permission logs.**
 - During the exit interview, the audit team identifies that the IT department has not submitted its latest access-control review or user-permission logs. The auditor asks who is responsible for providing the information and establishes a

deadline for submission before the report is finalized.

B4 WHAT TO PREPARE BEFORE THE AUDITORS LEAVE

WHAT TO PREPARE BEFORE THE AUDITORS LEAVE

- **Set a Target Date for the Draft Audit Report**
 - Establish when the draft audit report is expected to be completed.
- **Determine the Approval Timeline**
 - Estimate how long the organization's internal review and approval process will take.
- **Set a Target Date for the Final Report**
 - Agree on when the final audit report is expected to be issued.

Establishing these dates helps the organization **schedule tasks according to the audit timeline** and **keeps everyone accountable** for meeting agreed deadlines.

B5 ADVANTAGES AND LIMITATIONS

ADVANTAGES

- **RESOLVES ISSUES EARLY**
 - Allows questions, misunderstandings, and missing information to be addressed before the report is finalized.
- **KEEPS EVERYONE ACCOUNTABLE**
 - Establishes responsibilities and target dates for outstanding items and reporting.
- **IMPROVES ACCURACY**
 - Allows the audited entity to provide additional context and correct possible misunderstandings or errors.
- **PREVENTS SURPRISES**
 - Ensures that findings and next steps are discussed before the final report is issued.

LIMITATIONS

- **NOT REQUIRED IN EVERY AUDIT**
 - The exit interview is held when necessary rather than being required for every audit.
- **TIME CONSTRAINTS**
 - Limited time may be available to present findings, answer questions, and discuss outstanding issues.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **ISSUES MAY REMAIN UNRESOLVED**
 - Disagreements between the auditor and audited entity may still remain. If differences of opinion remain, they may simply be documented and included in the audit report.
- **COMMUNICATION GAPS**
 - Technical audit findings may be difficult for some participants to understand.

C DATA ANALYSIS

DATA ANALYSIS

- It means the **intelligence generated from reviewing audit-related information**, often using technology. Like other types of data analytics, audit analytics typically involve **analyzing large sets of numbers to find actionable audit insights**.

CI THE FIVE STEPS TO GET YOU STARTED WITH DATA ANALYSIS

STEP 1: DEFINE QUESTIONS AND GOALS

- The **first step** in data analysis is to clearly define your questions and goals. Like **creating a hypothesis** before an experiment, you should be asking a **targeted question** before searching the data for an answer. For example, questions about overall performance can be open-ended and it can be hard to pinpoint which metrics are needed for analysis. Instead, it is more advantageous to ask questions such as **"How have certain metrics changed over time?"** and **"Do these metrics correlate with others, and if so, how strongly?"** These types of questions have a **specific focus** which will help determine the **type of analysis needed** and **what data is the most relevant** to include.

STEP 2: COLLECT DATA

- Before you can start analyzing, there needs to be **data available for use**. Data can include sales records, customer demographics, lead tracking, net promoter scores, and more. When using a business intelligence tool, it is important to make sure that **all of the data is accessible** and the **proper connections are set** between your **data warehouse and your BI tool of choice**. Ultimately the **volume** of data required will depend on the **question** you wish to answer. Though you may only need a subset of the data collected, not

having enough data can skew the results of your analysis.

STEP 3: DATA WRANGLING

- Now that you have all of your data in one place, it is important to **clean the data before beginning the analysis portion** of this process. A large part of the cleansing process includes making sure that the **data is in a usable format**. This entails searching for **outliers**, dealing with **null values**, and looking for data that may have been **incorrectly input**. Often this can be a **lengthy and arduous** process.

STEP 4: DETERMINE ANALYSIS

- Once the relevant data is available and cleansed, it is time to analyze. Choosing a method of analysis will **heavily depend on the question or goals** defined earlier and the type of analysis needed.
- **Diagnostic analysis** uses **data to search for the cause of**, and a **solution to**, an existing problem.
- **Descriptive analysis** is a way to **describe the data by summarizing key sections**.
- **Predictive analysis** combines **historical data** and **statistical modeling** to forecast how certain metrics will perform in the future.

STEP 5: INTERPRET RESULTS

- After analyzing your data, it is important to interpret the results. Simply put, **what are you learning from the results of your analysis?** Combining multiple visualizations in one report enables the users to **tell a story about their data** that **leaders can use** to take **actions**, make **changes**, or **refocus** efforts accordingly. This step is key to **gaining insights from the data** and being able to **apply these insights** to your business.
- With these steps, you will be able to **use data analysis to unlock powerful new insights** that can be turned into **actionable results**. These insights could lead to **more questions** that prompt you to **dig even deeper** into the data and **start the analysis cycle again**.

D GENERATION OF AUDIT REPORTS

GENERATION OF AUDIT REPORTS

- The auditor **gathers evidence and observes, tests, compares** and **confirms** until gaining **reasonable assurance** and **forms an opinion** of whether the financial statements are **free of fraud or error**. In sum, this is the purpose



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

of an audit report. The auditor then presents an **audit opinion**.

PURPOSE

- Formal Communication
- Documentation of Evidence
- Initiation of Corrective Action Closure

BENEFITS

- Actionable Roadmap
- Strategic Oversight
- Historical Benchmarking
- Accountability

D1 AUDIT REPORT FORMAT

1. TITLE

- The title should mention - '**Independent Auditor's Report**'.

2. ADDRESSEE

- The addressee should mention **to whom** the report is being presented.

3. INTRODUCTORY PARAGRAPH

- A **statement** that the **financial statements described** in the report have been audited.

4. MANAGEMENT'S RESPONSIBILITY

- This section of the audit reports format should mention the Management's Responsibility for the **integrity** of the financial statements, which gives an **overview of the company's financial condition, cash flows, and financial performance**. It should mention that the **financial statements** are the **responsibility** of the organization's management. It is their responsibility to **formulate and execute necessary financial controls** to ensure the **accuracy** of the financial records. The responsibility also includes the **maintenance of accounting records** to prevent fraud.

5. AUDITOR'S RESPONSIBILITY

- The auditor's responsibility is to **plan and execute** the audit to **procure assurance** regarding the financial statements. The Auditor's responsibility is to **depict an unbiased opinion** on the financial statements and **issue an audit report**. The report is based on **Standards on Auditing**. The Standards require that the **auditor complies with ethical requirements**.

6. OPINION

- The **most critical** content in an Audit Report is the Auditor's Opinion. It mentions the **impression derived after auditing** the financial statements.

7. BASIS OF THE OPINION

- It should mention the **basis of achieving the opinion** as reported and the **facts** of the premise.

8. OTHER REPORTING RESPONSIBILITY

- **Any other responsibility** relating to reporting exists. It may include **Regulatory requirements**. The auditor has to mention the same.

9. SIGNATURE OF THE AUDITOR

- The auditor needs to **sign** the audit report, thereby **confirming the report's authenticity**

10. PLACE OF SIGNATURE

- The **name of the city** in which the **signing** of the report **happened**.

11. DATE OF AUDIT REPORT

- The **date** on which the audit report is **signed/reported**

E PRESENTATION FINDINGS

PRESENTATION FINDINGS

- Presentation of findings is the stage where the **audit team formally communicates** and **discusses the results** of the audit — **findings, conclusions, and recommendations** — with relevant **stakeholders** once the audit report is finalized or nearing finalization.

KEY ELEMENTS COVERED IN THE PRESENTATION



E1 PURPOSE OF THE PRESENTATION OF FINDINGS

PURPOSE OF THE PRESENTATION OF FINDINGS

- The presentation gives the audit team and stakeholders a **shared moment to understand results, decide on action, and move forward** with clear accountability.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Communicate Results**
 - Ensure stakeholders clearly understand what the audit uncovered.
- **Ensure Accountability**
 - Assign ownership of recommendations and agree on timelines.
- **Support Decision-Making**
 - Give management the information needed to prioritize and act.
- **Promote Transparency**
 - Build trust by openly discussing both strengths and weaknesses.

E2 HOW FINDINGS ARE PRESENTED

STEP 1: PREPARE A CLEAR SUMMARY

- **Organize findings** by **priority** or **risk** level, not by discovery order.

STEP 2: USE VISUAL AIDS

- **Charts** and **risk matrices** help non-technical stakeholders follow quickly.

STEP 3: STATE FINDING, IMPACT, FIX

- **For each issue:** what was found, why it matters, what to do.

STEP 4: OPEN THE FLOOR

- **Let management respond** and **clarify** before conclusions are locked in.

STEP 5: DOCUMENT AGREED ACTIONS

- **Record decisions, owners, and deadlines** during the meeting.

E3 WHAT TO PREPARE BEFORE THE PRESENTATION

FINALIZE THE REPORT DRAFT

- Ensure findings, evidence, and recommendations are **accurate** and **complete**.

ANTICIPATE QUESTIONS

- Prepare **supporting evidence** for findings likely to be challenged.

PRIORITIZE FINDINGS

- **Rank issues by severity or risk** so critical items are discussed first.

SET AN AGENDA

- **Allocate time per topic** so discussion doesn't run over or skip items.

E4 ADVANTAGES AND LIMITATIONS

ADVANTAGES

- **ENSURES UNDERSTANDING**
 - Reduces the chance findings are misread before action is taken.
- **DRIVES ACCOUNTABILITY**
 - Assigns clear ownership and deadlines for fixes.
- **BUILDS BUY-IN**
 - Stakeholders act faster on findings they helped discuss.
- **SURFACES CONTEXT**
 - Management may explain factors the audit team missed.

LIMITATIONS

- **TIME-CONSTRAINED**
 - Complex findings may need to be condensed, losing nuance.
- **STAKEHOLDER RESISTANCE**
 - Management may dispute or downplay findings.
- **TECHNICAL GAPS**
 - Non-technical audiences may struggle with audit language.
- **DELAYED FOLLOW-THROUGH**
 - Agreement in the room doesn't guarantee timely action.

L4: LOG INFORMATION AND SECURITY CONTROLS

TOPIC OVERVIEW

- A. INTRODUCTION TO SECURITY LOGGING
- B. TYPES OF LOG INFORMATION TO CAPTURE
- C. INTRUSION DETECTION SYSTEM (IDS)
- D. VERIFYING SECURITY CONTROLS
- E. PROTECTING LOGS
 - a. Log Review And Incident Response
- F. INTRUSION DETECTION ANALYSIS METHODS
- G. THE CORE DETECTION METHODS
- H. SUPPLEMENTARY PROFILING TECHNIQUES
- I. HOST BASED INTRUSION DETECTION



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

SYSTEM

J. LAYERED DEFENSE

K. NETWORK ACCESS CONTROL

L. HOST ISOLATION

- When And Why Host Isolation Is Used
- Main Objectives Of Isolation
- Verifying Host Isolation

M. SYSTEM HARDENING

N. MONITORING AND TESTING SECURITY SYSTEM

A INTRODUCTION TO SECURITY LOGGING

INTRODUCTION TO SECURITY LOGGING

- Security logs **record activities** occurring on computers, networks, applications, and security devices.
- Logs help organizations:**
 - Detect** unauthorized access.
 - Investigate** security incidents.
 - Verify** security controls.
 - Support** audits and compliance.
- Important log questions include:**
 - Who** performed the action?
 - What** happened?
 - When** did it happen?
 - Where** did it originate?

B TYPES OF LOG INFORMATION TO CAPTURE

TYPES OF LOG INFORMATION TO CAPTURE

1. Authentication logs

- Successful and failed logins.
- Password changes.
- Multi-factor authentication events.
- Account lockouts.

2. Authorization logs

- Access to restricted files.
- Privilege changes.
- Administrative actions.

3. Network logs

- Firewall connections.
- Blocked traffic.
- VPN activity.
- Network scans.

4. System and application logs

- Operating-system errors.
- Software installations.
- Configuration changes.
- Application failures and user transactions.

IMPORTANT LOG DETAILS

- Each security event should contain enough information for investigation.

Log detail	Purpose
Timestamp	Shows when the event occurred
Event type	Identifies the activity
User or account	Identifies who performed the action
Source address	Shows the originating device or IP address
Destination system	Identifies the affected resource
Result	Shows whether the action succeeded or failed
Severity	Helps prioritize investigation
Log source	Identifies the device or system that created the record

- National Institute of Standards and Technology (NIST)** identifies the **timestamp**, event **type**, event **source**, and **sensor** or reporting system as **important information** for IDPS events.

C INTRUSION DETECTION SYSTEM (IDS)

INTRUSION DETECTION SYSTEM (IDS)

- An Intrusion Detection System (IDS) **monitors activity** and **detects possible attacks** or policy violations. An IDS generally **generates alerts** rather than blocking activity automatically.
- IDS can monitor:**
 - Network traffic.
 - System activity.
 - User behavior.
 - Application events.
 - Authentication attempts.
- Main IDS types:**
 - Network-based IDS (NIDS):** Monitors network traffic.
 - Host-based IDS (HIDS):** Monitors individual computers or servers.
- IDS technologies help organizations **detect** and **investigate** suspicious activity.

IDS LOG INFORMATION

- Alert** identification number.
- Date** and **time** of detection.
- Source** and **destination** IP addresses.
- Ports** and **network** protocol.
- Detection **rule** or **signature**.
- Suspected **attack type**.
- Severity **level**.
- Affected** host, account, or application.
- IDS sensor** that generated the alert.
- Response** or **action** taken.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

DETECTION METHODS

- **Signature-based:** Detects known attack patterns.
- **Anomaly-based:** Identifies activity that differs from normal behavior.
- **Protocol analysis:** Detects improper use of network protocols.
- **Event correlation:** Combines multiple events to identify a larger attack.

D VERIFYING SECURITY CONTROLS

Security controls should be tested to confirm that they work as intended.

- **Review** system and IDS configurations.
- Confirm that **logging is enabled** on important devices.
- Perform an authorized failed-login or **test intrusion**.
- **Verify** that the activity creates a log entry.
- Confirm that the **IDS generates the correct** alert.
- Check whether **alerts reach the security** team or SIEM.
- **Validate timestamps** and required log fields.
- **Review false positives** and missed events.
- **Document** test results and corrective actions

Testing should be **authorized** and performed in a **controlled environment**.

E PROTECTING LOGS

PROTECTING LOGS

- **Store logs** in a centralized log-management platform or **SIEM**.
- **Restrict log access** to authorized personnel.
- **Encrypt logs** during transmission and storage.
- **Separate log storage** from the systems generating the logs.
- **Monitor attempts** to modify or delete logs.
- Use **hashes, digital signatures, or append-only storage** to protect integrity.
- Establish **retention and disposal policies**.
- Monitor whether **log sources stop sending data**.
- **Protect logs** because they may contain **sensitive** user, system, and security information.

Log management includes **generating, transmitting, storing, accessing, and disposing** of log data.

E1 LOG REVIEW AND INCIDENT RESPONSE

LOG REVIEW AND INCIDENT RESPONSE

- Logs should be **reviewed continuously** or according to a **documented schedule**.

SECURITY TEAMS SHOULD INVESTIGATE:

- Repeated failed **logins**.
- **Privilege** escalation.
- Disabled **security** services.
- **Malware** detection.
- Unexpected **administrator activity**.
- Large or unusual **data transfers**.

IDS alerts should be **correlated** with **firewall, authentication, endpoint, and application logs**.

WHEN SUSPICIOUS ACTIVITY IS IDENTIFIED:

1. **Validate** the alert.
2. **Identify** affected systems.
3. **Preserve** relevant evidence.
4. **Contain** the activity.
5. **Investigate** and document the incident.
6. **Improve** security controls based on the findings.

Regular log review helps organizations **detect threats earlier** and **improve their security posture**.

F INTRUSION DETECTION ANALYSIS METHODS

INTRUSION DETECTION ANALYSIS METHODS

- are the **core methodologies** that Intrusion Detection Systems (IDS) and security analysts use to **inspect network traffic, system events, and log files** to discover **unauthorized or malicious** activities

G THE CORE DETECTION METHODS

THE CORE DETECTION METHODS

- **Signature-Based Detection**
 - Matches data against a database of known threat indicators.
- **Anomaly-Based Detection**
 - Flags any activities that deviate from an established baseline of normal behavior.
- **Stateful Protocol Analysis**
 - Evaluates traffic based on standard protocol specifications to find structural deviations.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

1. SIGNATURE-BASED ANALYSIS

- Also known as **Misuse Detection**, this method **scans network packets** and **system logs** for specific **patterns, byte sequences**, or **malicious instruction** code—known as **"signatures"**—that **match recorded threats**.
- Pros:** Highly accurate for known threats; generates very few false positives.
- Cons:** Entirely blind to new, zero-day vulnerabilities and morphing malware.

2. ANOMALY-BASED ANALYSIS

- This method relies on **machine learning** or **statistical modeling** to build a **rigid baseline profile** of standard system or network operations. Once established, the system **logs any deviation** from this baseline as a **potential attack**.
- Pros:** Capable of detecting brandnew, novel, or zeroday threats.
- Cons:** High rate of false positives caused by legitimate, unusual user spikes or system changes.

3. STATEFUL PROTOCOL ANALYSIS

- Also known as **Specification-Based analysis**, this method **compares network activity against universal vendor profiles** of how **protocols** should structurally **behave**. It tracks the **state of network pairings** over time. This is different from anomaly detection which learns **"normal" behavior** from history.
- Pros:** Easily catches protocol manipulation, illegal commands, and scanning attempts.
- Cons:** Consumes heavy system resource overhead to continuously track state conditions across layers.

H SUPPLEMENTARY PROFILING TECHNIQUES

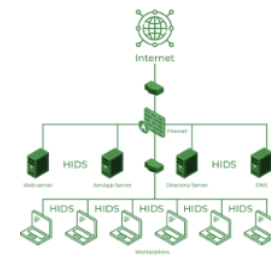
Beyond the primary engines, advanced modern frameworks implement specific profiling layers:

- Threshold Monitoring:**
 - Alerts defenders when **pre-set operational limits** are **broken** (e.g., failed login attempts).
- Resource Profiling:**
 - Tracks **system-wide consumption metrics** like CPU, RAM, and bandwidth to find **sneaky background malware**.
- Executable Profiling:**
 - Continuously **analyzes how active** software programs **invoke system calls** and **read system memory**.

I HOST BASED INTRUSION DETECTION SYSTEM

HOST BASED INTRUSION DETECTION SYSTEM

- Host-based Intrusion Detection System (HIDS) is a cybersecurity tool that **monitors an individual device or host for suspicious activity, unauthorized file changes**, and **malicious behavior**.



HOW DOES IT WORK?

- Data Collection:**
 - The HIDS agent **gathers raw data directly from the host**, including system logs, application event logs, authentication records, and kernel activities.
- File Integrity Monitoring (FIM):**
 - It **tracks critical system files, configuration settings**, and **executables** by **comparing current states against baseline snapshots** to catch unauthorized changes.
- Analysis and Matching:**
 - The system **evaluates the collected data** using two main techniques: **Signature-based** and **Anomaly-based**.
- Alerting and Logging:**
 - When a rule violation or threat is found, the HIDS **logs the event details** and immediately **sends an alert** to security administrators for response.

COMPARISON TO NIDS

	Host-Based Intrusion Detection System	Network-Based Intrusion Detection System
Scope	Monitors single endpoint	Monitors traffic across an entire network segment
Placement	runs as an agent directly to host OS	sits at strategic network points (eg. routers and firewalls) using tapos or promiscuous mode
Encrypted Traffic	reads data after it is decrypted on the device	difficult to inspect encrypted payloads without specialize decryption tools
Blind Spots	broader network-level attacks, activity targeting other machines	local file tampering, insider activity that doesn't generate any unusual network traffic



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

J LAYERED DEFENSE

LAYERED DEFENSE

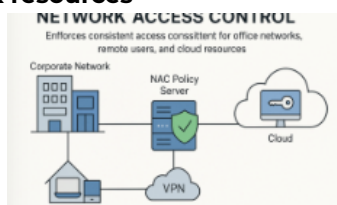
- Layered defense, also known as **defense in depth**, is a security strategy that uses **multiple security controls at different levels** of an information system.
- Instead of depending on a single security mechanism, organizations create **several defensive layers**.
- If one layer fails** or is bypassed, **another layer can still detect, prevent, or limit** the attack.

Security Layer	What it protects	Examples
1. Physical Security	Physical access to equipment	Locks, guards, access cards, cameras
2. Network Security	Network connections and traffic	Firewalls, segmentation, NAC
3. Detection	Identifies suspicious activity	IDS/IPS, traffic analysis
4. Endpoint/Host Security	Individual computers and servers	Antivirus/EDR, HIDS, host firewall
5. Application Security	Applications and their functions	Authentication, authorization, input validation
6. Data Security	Information itself	Encryption, backups, access controls
7. Monitoring & Logging	Visibility and investigation	Logs, SIEM, alerts, audit trails

K NETWORK ACCESS CONTROL

NETWORK ACCESS CONTROL

- Network Access Control (NAC) is a security approach that **controls which users and devices** are **allowed to connect** to and **use network resources**



NAC CAN EVALUATE

- User identity**
 - Username
 - Authentication credentials
 - User role
- Device identity**
 - Device type

- MAC address
- Device certificate
- Device ownership

- Security posture**

- Operating system
- Security updates
- Endpoint protection status
- Security configuration

- Network requirements**

- Which network the device should access
- Which resources the user should be allowed to reach

POSSIBLE NAC DECISIONS

- Allow
- Deny
- Restrict
- Quarantine

NETWORK ACCESS CONTROL PROCESS

- NAC generally follows a sequence of identification, authentication, assessment, authorization, and monitoring.
- Identification**
 - The NAC system determines **information** about the device and user.
- Authentication**
 - The user or device **proves its identity**
- Security Assessment**
 - The NAC system can determine whether the device **meets security requirements**
- Authorization**
 - The NAC system determines what **level of access** should be provided.
- Monitoring**
 - The device's **network activity** can continue to be **monitored** and **logged**.

VERIFYING NETWORK ACCESS CONTROL

- Network Access Control must be **tested regularly** to determine whether its policies are actually being enforced.
- Authorized User**
 - An authorized employee should be able to **access the resources** required for their role.
- Unauthorized User**
 - An unauthorized account **should not receive access** to protected resources.
- Unknown Device**
 - A device that is **not recognized** or **approved** should be tested.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Non-Compliant Device**
 - **Test a device** that intentionally does **not meet** the organization's requirements.
- **Disabled Account**
 - **Attempt authentication** using an account that has been disabled.

L HOST ISOLATION

HOST ISOLATION

- Host isolation is a security technique that **separates a computer, server, or endpoint from other systems** when the **host is suspected of being compromised** or presenting a security risk.
- The primary purpose is **containment**.
- Instead of immediately shutting down the computer, security administrators may **isolate its network communication** so that investigators **can still examine** the system.

WHY IS HOST ISOLATION NECESSARY?

- A **compromised computer** could potentially:
 - Spread malware
 - Attack other computers
 - Steal credentials
 - Communicate with an attacker's server
 - Access sensitive resources
 - Transfer stolen information
 - Serve as a starting point for further attacks

L1 WHEN AND WHY HOST ISOLATION IS USED

HOST ISOLATION

- is normally considered when there is a **reasonable indication** that a device may be **compromised**.

POSSIBLE INDICATORS

- **Malware Detection**
 - Malware or ransomware is detected.
- **Suspicious Processes**
 - An unknown or malicious process is running.
- **Abnormal Network Connections**
 - The computer communicates with suspicious external systems.
- **Credential Compromise**
 - A user's credentials may have been stolen.
- **Data Exfiltration**

- An unusual amount of information is being transferred outside the organization.

- **Unauthorized System Changes**
 - Important system files or configurations have been modified.
- **IDS/HIDS Alerts**
 - Security monitoring detects suspicious activity originating from the host.

L2 MAIN OBJECTIVES OF ISOLATION

MAIN OBJECTIVES OF ISOLATION

1. **Containment**
 - Prevent the threat from spreading.
2. **Protection**
 - Protect other systems and sensitive information.
3. **Investigation**
 - Allow security personnel to examine the affected host.
4. **Evidence Preservation**
 - Avoid unnecessary changes that could destroy useful investigation evidence.
5. **Recovery**
 - Provide time to remove the threat and restore the system safely.

L3 VERIFYING HOST ISOLATION

VERIFYING HOST ISOLATION

- After isolating a potentially compromised host, administrators must verify that the isolation is working correctly.

VERIFICATION STEPS

1. **Identify the Host**
 - Confirm the affected device and reason for isolation.
2. **Apply Isolation**
 - Use NAC, endpoint security, firewall rules, or network segmentation.
3. **Test Connectivity**
 - Check whether the host can still access restricted systems.
4. **Review Logs**
 - Examine firewall, NAC, IDS, and endpoint logs for connection attempts.
5. **Compare Results**
 - Make sure actual behavior matches the isolation policy.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

6. Document Findings

- Record the tests, results, and any problems discovered.

M SYSTEM HARDENING

SYSTEM HARDENING

- System hardening is the process of **securing a computer system** by **reducing or eliminating vulnerabilities** that could be exploited by attackers. It involves **configuring the operating system, applications, network services, and user accounts** according to security best practices.
- Without hardening, systems **may contain unnecessary services, outdated software, weak passwords, or excessive user privileges**. These weaknesses can provide attackers with **opportunities to gain unauthorized access**.
- Reduce** the number of possible attack surfaces
- Prevent** unauthorized access to systems and data
- Protect** systems from malware and other cyber threats
- Ensure** security configurations are properly implemented
- Minimize** unnecessary services, applications, and permissions

WHY IS IT IMPORTANT?

- Without hardening, systems may contain unnecessary services, outdated software, weak passwords, or excessive user privileges. These weaknesses can provide attackers with opportunities to gain unauthorized access
- Example:** A company server running an outdated service may contain a known vulnerability. An attacker could exploit that vulnerability to access the server. Applying security updates and disabling unnecessary services reduces this risk

N MONITORING AND TESTING SECURITY SYSTEM

MONITORING AND TESTING SECURITY SYSTEM

- Detect** suspicious behavior
- Identify** possible security incidents
- Discover** unauthorized access
- Track** changes to systems
- Provide information** for incident investigation

- Verify** that security controls are operating correctly

MONITORING AND TESTING SECURITY SYSTEM

- Security monitoring and testing is the process of **continuously observing systems** and **regularly testing security controls** to determine whether they are functioning correctly and protecting against threats.
- Monitoring** involves **collecting** and **examining information** about system and network activity. **Security testing evaluates** whether security controls **can actually protect a system** and **detect potential threats**.
- Testing** should be **performed regularly** because new vulnerabilities and threats can appear over time.

COMMON SECURITY TESTING METHODS

- Vulnerability Scanning**
 - Searches** systems for known security **weaknesses**
 - Identifies outdated** software and **insecure** configurations
- Penetration Testing**
 - Simulates controlled attacks** against a system
 - Determines whether **vulnerabilities** can actually be **exploited**
- Security Audits**
 - Review** **security** policies, configurations, and procedures
 - Verify compliance** with security requirements
- Log and Alert Testing**
 - Generates **controlled security events**
 - Checks whether **monitoring tools** **properly record** and **report** them

L5: POST AUDIT ACTIVITIES

TOPIC OVERVIEW

- A. EXIT INTERVIEW**
- B. DATA ANALYSIS**
- C. AUDIT REPORT**
 - a. Parts of an Audit Report
 - b. Presentation of Audit Findings
 - c. Qualities Of A Good Audit Report
 - d. Summary
- D. PRESENTATION OF FINDINGS**
 - a. Advantages and Disadvantages
 - b. Example



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

A

EXIT INTERVIEW

DESCRIPTION

- **Definition:**
 - The **final formal meeting** conducted between the **security audit team** and key **organizational stakeholders/management** before the official audit report is published.
- **Core Concept:**
 - Acts as an **initial, verbal debriefing** session designed to discuss the **execution** of the audit, **initial observations**, and **preliminary findings** in a controlled environment.
- **Context in Security Auditing:**
 - Represents the **transition** point from **active field testing** and **evidence collection** to **formal reporting** and **remediation planning**.

PURPOSE

- **Prevent "No Surprises":**
 - Ensures executive management and system owners are **not caught off guard by critical findings** when the formal report is released.
- **Fact Verification & Validation:**
 - Gives the audited team an **opportunity to review gathered evidence**, **clarify misunderstandings**, and **correct factual inaccuracies** before finalization.
- **Provide Operational Context:**
 - Allows administrators to **explain specific operational constraints** or **business reasons** behind certain system configurations.
- **Align Expectations:**
 - Establishes a **mutual understanding** regarding the **severity of findings**, **report delivery timelines**, and **post-audit responsibilities**.

FORMAT

- **Meeting Structure:**
 - A **structured, high-level briefing** held either in-person or via a secure, recorded video conference.
- **Duration & Atmosphere:**
 - Typically lasts between **30 to 60 minutes**, maintaining a **professional, objective**, and **collaborative** tone.

- **Supporting Artifacts:**
 - Supported by an **Executive Summary** slide deck or a **brief preliminary position paper** detailing top-level metrics.

KEY PARTS

1. **Executive Opening & Scope Review:**
 - Brief **recap** of the **agreed-upon** audit **boundaries**, **systems** evaluated, and **timeline** executed.
2. **Positive Observations:**
 - **Recognition** of effective **security controls**, **robust practices**, and **well-maintained systems** already in place.
3. **Preliminary Risk & Finding Highlights:**
 - Overview of **key vulnerabilities** discovered, categorized by **high-level threat levels** (Critical, High, Medium).
4. **Interactive Discussion / Management Feedback:**
 - Dedicated **time** for the client team to **ask questions**, present **additional context**, or **challenge findings**.
5. **Next Steps & Deliverable Timeline:**
 - Clear roadmap detailing **data analysis completion**, **final report delivery**, and **formal response deadlines**.

PRESENTATION STRATEGY

- **Focus on Business Impact:**
 - **Translate complex** technical exploits into **tangible business risks** (e.g., potential data breaches, operational downtime, or regulatory non-compliance).
- **Adopt a Collaborative Tone:**
 - Frame **findings as opportunities** for **strengthening defense-in-depth** rather than placing personal blame on technical teams.
- **Balanced Delivery:**
 - Open with **effective security controls** before **transitioning** into identified vulnerabilities to **maintain engagement** and **reduce defensiveness**.
- **Be Direct and Precise:**
 - Present **high-priority issues clearly** without diluting the severity of critical security risks.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

QUALITIES OF A GOOD EXIT INTERVIEW

- **Objective & Evidence-Based:**
 - Every statement is **grounded** in **verifiable logs, screenshots, or configuration files**—never assumptions or personal opinions.
- **Transparent:**
 - **Clear** about **what was tested, testing limitations, and any scope areas** that could not be evaluated.
- **Constructive:**
 - Focuses on **actionable risk mitigation and improvement strategies** rather than punitive fault-finding.
- **Interactive:**
 - Encourages **open dialogue**, allowing system owners to **provide context without fear** of immediate dismissal.

SUMMARY

- **Core Takeaway:**
 - The Exit Interview is a **crucial communication bridge** in the auditing process. It builds **trust**, verifies **accuracy**, **eliminates surprises**, and sets a **collaborative foundation** for fixing security vulnerabilities.

B

DATA ANALYSIS

DESCRIPTION

- **Definition:**
 - The systematic process of **inspecting, cleaning, transforming, and evaluating raw data and security evidence** collected during an audit.
- **Core Concept:**
 - **Converts raw technical logs, system outputs, and scanner findings** into structured, actionable **security intelligence**.
- **Context in Security Auditing:**
 - Serves as the **critical analytical bridge** between **raw evidence gathering** and the **generation of the final audit report**.

PURPOSE

- **Identify Root Causes:**
 - Moves **beyond surface-level symptoms** to discover the **underlying misconfigurations, policy failures, or architecture gaps**.

- **Risk Prioritization:**
 - **Evaluates findings** based on **Likelihood vs. Impact** to determine where the organization should allocate remediation resources first.
- **Verify Compliance:**
 - **Validates technical configurations** against established **baseline security standards** and **legal frameworks** (e.g., ISO 27001, NIST, PCI-DSS).
- **Eliminate False Positives:**
 - **Filters out inaccurate automated scanner alerts** to ensure management focuses only on genuine security threats.

FORMAT

- **Workflow Framework:**
 - A structured analytical process combining **automated software processing** with **expert manual verification**.
- **Analytical Tools Used:**
 - **SIEM** (Security Information and Event Management) software, **log parsers**, **script-based data filters**, and **risk matrix models**.
- **Output Structure:**
 - Formatted metrics, threat maps, correlated attack paths, and quantitative risk scores.

KEY PARTS

1. **Data Normalization & Cleaning:**
 - **Aggregating data** from multiple sources, standardizing formats, and stripping out false positives.
2. **Correlation & Pattern Analysis:**
 - **Cross-referencing firewall logs, server event logs, and intrusion detection alerts** to **trace malicious activity paths**.
3. **Severity Assessment & Scoring:**
 - Applying **standardized scoring frameworks** (e.g., CVSS) to evaluate **vulnerability severity** objectively.
4. **Root Cause Breakdown:**
 - **Mapping identified vulnerabilities** to systemic **weaknesses**, such as lack of patch management or weak access controls.
5. **Trend & Historical Comparison:**
 - **Benchmarking current findings** against **previous audit cycles** to measure **security posture growth** over time.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

PRESENTATION STRATEGY

- **Leverage Visual Data Representations:**
 - Use **risk heat maps, vulnerability distribution pie charts, and timeline graphs** to make complex data readable.
- **Structure around Narrative Attack Paths:**
 - Tell a **cohesive story** showing **how a single low-level vulnerability** could be **chained with others** to compromise critical assets.
- **Distinguish Confirmed vs. Potential Risks:**
 - Clearly differentiate between **empirically proven vulnerabilities** and **theoretical attack vectors**.
- **Focus on Actionable Metrics:**
 - Present data in terms of **actionable metrics** (e.g., Time-to-Remediate, High-Risk Exposure Count) rather than overwhelming raw log dumps.

QUALITIES OF A GOOD DATA ANALYSIS

- **Accurate & Defensible:**
 - **Free from false positives** and supported by **verifiable evidence chains**.
- **Context-Aware:**
 - **Evaluates vulnerability severity** based on the organization's unique **business context, asset criticality, and network environment**.
- **Reproducible:**
 - **Methodology is clear enough** that another security professional could analyze the same raw data and reach identical conclusions.
- **Outcome-Oriented:**
 - **Directly informs actionable remediation steps** rather than providing passive, unusable statistics.

SUMMARY

- **Core Takeaway:**
 - Data Analysis turns **chaotic, raw security data** into **precise, actionable risk intelligence**. It provides the **empirical proof** required to justify technical changes, strategic planning, and security budget allocations.

C AUDIT REPORT

GENERATION OF AUDIT REPORT

- The generation of an audit report is the process of **compiling the evidence, analysis,**

observations, and findings gathered throughout the audit into a **formal written document**. It **summarizes the results of the audit** and provides stakeholders with a clear understanding of the **organization's security and control conditions**.

- The report also communicates the **auditor's overall conclusion or opinion** based on the **evidence** collected. It may **identify risks, weaknesses, and areas** that **require improvement**, allowing management to understand the audit results and take appropriate **corrective actions**.

PURPOSE OF AN AUDIT REPORT

- An audit report serves as an **official record of the audit activities and results**. It documents the **evidence examined, issues identified, and conclusions** reached by the auditor. It provides stakeholders with **reliable information** about whether established policies, procedures, controls, or requirements are being properly followed.
- It also helps management understand **potential risks and weaknesses** within the organization. Through the report, auditors can **communicate their findings and recommendations**, which can guide management in **making decisions** and **implementing corrective actions** to improve security and compliance.

AUDIT REPORT FORMAT

- An audit report follows a **structured format** to ensure that important information is **presented clearly and consistently**. **Each section has a specific purpose**, beginning with the **identification** of the report and its **recipient**, followed by **information** about the audit, the **responsibilities** of management and the auditor, and the **auditor's opinion**.
- The format also identifies the **basis for the opinion** and other required **reporting responsibilities**. Finally, the **auditor's signature, place of signature, and date** are included to formally establish the authenticity and completion of the audit report.

C1 PARTS OF AN AUDIT REPORT

PARTS OF AN AUDIT REPORT

- **Title** – Identifies the document as an official audit report.
- **Addressee** – States who the audit report is intended for.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Introductory Paragraph** – Provides the background, purpose, and scope of the audit.
- **Management's Responsibility** – Explains management's responsibility for the financial information, systems, or controls being audited.
- **Auditor's Responsibility** – Describes the auditor's duty to conduct the audit and evaluate the evidence.
- **Opinion** – Presents the auditor's conclusion based on the audit results.
- **Basis of the Opinion** – Explains the evidence and procedures supporting the auditor's opinion.
- **Other Reporting Responsibility** – Includes additional matters that the auditor is required to report.
- **Signature of the Auditor** – Identifies the auditor who conducted or approved the audit report.
- **Place of Signature** – Indicates the location where the report was signed.
- **Date of Audit Report** – States the date when the audit report was completed and issued.

C2 PRESENTATION OF AUDIT FINDINGS

PRESENTATION OF AUDIT FINDINGS

- Audit findings **communicate the problems, weaknesses, or risks** discovered during the audit. They should be **presented clearly and objectively**, with each finding supported by **sufficient evidence**. This allows stakeholders to understand exactly **what** was observed and **why** the issue is considered a concern.
- A finding may describe the **condition, criteria, cause, effect or risk, and recommended corrective action**. Organizing findings in this way helps management understand the **significance of each issue** and determine the **appropriate actions** needed to address or reduce the identified risks.
- **Finding Components:**
 - **Condition** – What was found or observed
 - **Criteria** – What should have been in place
 - **Cause** – Why the issue occurred
 - **Effect/Risk** – Possible impact
 - **Recommendation** – Action needed to address the issue

C3 QUALITIES OF A GOOD AUDIT REPORT

QUALITIES OF A GOOD AUDIT REPORT

- A good audit report should present information that is **accurate, objective, clear, constructive, timely, and confidential**. These qualities help ensure that the report is **reliable and understandable** to both technical personnel and management, while **preventing unsupported claims** or **unnecessary bias** in presenting the audit results.
- The recommendations should also be **practical and actionable** so that management can use them to address identified weaknesses. Since audit reports may contain sensitive information about systems and security controls, **appropriate confidentiality and distribution practices** should also be maintained.
 - **Accurate** – Supported by evidence
 - **Objective** – Free from personal bias
 - **Clear** – Easy to understand
 - **Constructive** – Provides practical solutions
 - **Timely** – Issued promptly
 - **Confidential** – Sensitive information is protected

C4 SUMMARY

SUMMARY

- The generation of an audit report **transforms the evidence and findings** gathered during the audit into a **formal document**. It provides stakeholders with a **structured presentation** of what was **examined**, what was **discovered**, and whether the organization's **controls and requirements were properly implemented**.
- The report ultimately **communicates the auditor's conclusion or opinion** and identifies **areas** that may **require improvement**. Through **documented findings and recommendations**, the audit report helps management **understand risks** and provides a **basis for appropriate corrective actions**.
- Audit Evidence → Analysis → Findings → Opinion/Conclusion → Audit Report



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

D PRESENTATION OF FINDINGS

CONCEPT

- The Presentation of Findings is the **pivotal final communication phase** in the post-audit lifecycle where **auditors formally deliver, explain, and contextualize** verified audit results to management, process owners, and governance committees. Rather than simply handing over raw data, this process **translates complex technical or operational evidence** into **clear business risks and practical opportunities** for improvement. It serves as the **bridge** between **investigative analysis** and **real-world corrective action**, ensuring organizational alignment on critical issues.
 - Core Purpose:** Transforms complex audit evidence into actionable business insights.
 - Strategic Role:** Connects technical analysis with executive decision-making and remediation.

DESCRIPTION

- This activity typically takes place in a **formal closing meeting, executive presentation, or board review** using **visual slide decks** and **summary exhibits**. The discussion is designed to be **constructive, transparent, and forward-looking**, moving away from fault-finding toward strengthening internal controls, regulatory compliance, and operational resilience.
 - Core Deliverables:** Summarizes key control gaps, operational risks, and policy non-compliances.
 - Risk Categorization:** Prioritizes issues using severity ratings (High, Medium, Low) to clarify operational impact.
 - Remediation Roadmap:** Outlines proposed Corrective Action Plans (CAP), implementation deadlines, and assigned accountability.

D1 ADVANTAGES AND DISADVANTAGES

ADVANTAGES

- Immediate Clarity & Direct Dialogue:**
 - Allows stakeholders to **ask clarifying questions** and **eliminates misunderstandings** before final reports are permanently archived.
- Faster Stakeholder Buy-in:**
 - Presenting findings interactively** helps executives see the business

impact immediately, **accelerating approval** for budgets and remediation resources.

- Shared Accountability:**
 - Establishes **consensus** on the **root causes of non-compliance** and clearly assigns **responsible parties for corrective actions**.
- Strategic Value Addition:**
 - Elevates the perception** of an audit from a policing exercise to a **value-driving partnership** that strengthens governance.

DISADVANTAGES

- Defensiveness & Conflict:**
 - Stakeholders may become **combative** or **dispute findings** if non-conformities reflect poorly on their department's performance.
- Misinterpretation Risk:**
 - Condensing detailed technical or financial data into summary presentation slides can lead to **oversimplification** or **taken-out-of-context takeaways**.
- Time & Resource Intensive:**
 - Preparing high-stakes visual decks and coordinating executive schedules **requires substantial auditor bandwidth**.
- Scope Creep during Discussion:**
 - Open-floor discussions can **easily derail into operational complaints or issues** beyond the defined scope of the audit.

D2 EXAMPLES

IT & Cybersecurity Audit:

- Finding:** "58% of employee workstations are missing critical security patches, and default administrator credentials were found active on network switches."
- Impact Presentation:** Visualizes the risk of ransomware infiltration and presents a mandatory 14-day automated patch deployment plan.

Financial Compliance & Inventory Audit:

- Finding:** "A 12% discrepancy exists between the ERP physical inventory logs and the warehouse cycle counts due to delayed manual data entry."



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Impact Presentation:** Displays loss trends via bar charts and proposes a barcode-scanning workflow to prevent reconciliation errors.

Quality & Safety (ISO/HACCP) Audit:

- **Finding:** "Storage temperatures in Cold Room B exceeded the 4°C limit three times during the quarter without documented corrective actions."
- **Impact Presentation:** Highlights regulatory non-compliance risks and presents an automated IoT temperature-alerting framework.

L6: RISK MANAGEMENT PROCESS

TOPIC OVERVIEW

- A. RISK IDENTIFICATION
- B. RISK ASSESSMENT
- C. IMPLEMENTING & MONITORING

A RISK IDENTIFICATION

WHAT IS RISK IDENTIFICATION?

- It is the process of **finding, recognizing**, and **documenting potential risks** that may affect a project.
- **STARTING POINT** of risk management process.
- "WHAT COULD GO WRONG WHILE DEVELOPING OUR SYSTEM?"

WHY IS RISK IDENTIFICATION IMPORTANT?

- **Recognize** potential problems early
- **Prepare** appropriate responses
- **Reduce** the possibility of response issues
- **Protect** the project's schedule, budget and objectives
- **Help** the team prioritize which risks need attention

COMMON RISK IDENTIFICATION TOOLS AND TECHNIQUES

1. BRAINSTORMING

- **Team members identify risks** such as lack of resources, technical errors, or delays.
- **EXAMPLE:** Team members identify risks such as lack of resources, technical errors, or delays.

2. CHECKLISTS

- A **list of common risks from previous projects or established standards** is used to identify possible risks.
- **EXAMPLE:** A software project checklist may include security problems, data loss, software bugs, and system downtime.

3. SWOT ANALYSIS

- SWOT examines:
 - S – **Strengths**
 - W – **Weaknesses**
 - O – **Opportunities**
 - T – **Threats**

4. EXPERT INTERVIEWS

- **People with specialized knowledge or experience** are asked about possible risks.
- **EXAMPLE:** A cybersecurity expert may identify security vulnerabilities that the project team might overlook.

5. DOCUMENTATION REVIEW

- **Existing project documents, contracts, schedules, requirements, and reports** are **reviewed** to find potential risks.

6. HISTORICAL INFORMATION

- The team **examines risks from previous or similar projects** to determine which risks might occur again.

MAIN OUTPUT: RISK REGISTER

- A risk register is a **document** that **records the risks identified** throughout the project.

THE RISK REGISTER

Project Name: Common Project Risks

Project name: Common project risks

ID	Date raised	Risk description	Likelihood of the risk occurring	Impact if the risk occurs	Severity Rating based on impact & likelihood	Owner Person who will manage the risk	Mitigating action Actions to mitigate the risk e.g. reduce the likelihood
1	[enter date]	Project purpose and need is not well-defined.	Medium	High	High	Project Sponsor	Complete a business case if not already provided and ensure purpose is well defined on Project Charter and PID.
2	[enter date]	Project design and deliverable definition is incomplete.	Low	High	High	Project Sponsor	Define the scope in detail via design workshops with input from subject matter experts.
3	[enter date]	Project schedule is not clearly defined or understood	Low	Medium	Medium	Project Manager	Hold scheduling workshops with the project team so they understand the plan and likelihood fo missed tasks is reduced.

PROCESS OF IDENTIFICATION

- Identify
- Document
- Record in Risk Register
- Proceed to Risk Assessment



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

B RISK ASSESSMENT

WHAT IS RISK ASSESSMENT?

- Process of **identifying, analyzing, and evaluating risks** to determine their **significance**
- Helps organizations decide **which risks need treatment** and in **what order**
- **Core output:** a prioritized understanding of **risk exposure**
- **Foundation** for **risk response planning** (accept, mitigate, transfer, avoid)

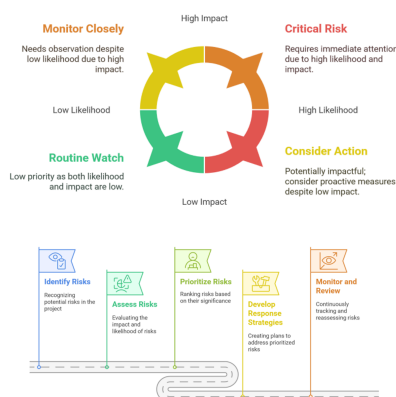
TWO APPROACHES TO RISK ASSESSMENT

- **Qualitative Risk Assessment**
 - Uses **descriptive, judgment-based ratings** like **Low/Medium/High** rather than hard numbers. It's **fast and easy** to communicate, relying on **expert experience** and **team discussion**.
- **Quantitative Risk Assessment**
 - Uses **numerical, data-driven** values such as dollar amounts and probabilities. It takes **more time and data** but supports **precise cost-benefit decisions**.
- **Example**
 - A startup gives a new vendor a quick "Medium" rating in a team discussion (qualitative), while a bank calculates a \$2.3M expected annual loss before approving a large loan (quantitative).

QUALITATIVE RISK ASSESSMENT

- Uses **descriptive** scales (high, medium, low)
- Relies on **expert judgment** and **experience**
- Requires **minimal mathematical** calculations
- Provides **quick assessment** results
- Works well with **limited historical data**

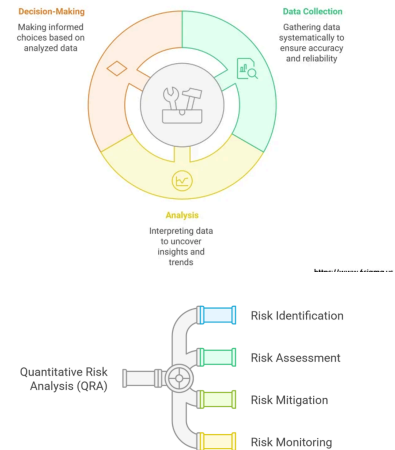
Qualitative Risk Analysis



QUANTITATIVE RISK ASSESSMENT

- Uses **numerical values** and **probabilities**
- Requires **statistical analysis tools**
- Demands **detailed historical data**
- Produces **specific numerical** outcomes
- Takes **longer** to complete

Statistical Tools



LIKELIHOOD AND IMPACT ANALYSIS

- **Likelihood:**
 - **probability** a risk event will occur
- **Impact:**
 - **severity** of consequences if it occurs
- Both usually **rated on a scale** (e.g., 1–5 or Low/Med/High)

$$\text{Risk Level} = \text{Likelihood} \times \text{Impact}$$



THE RISK MATRIX

- Visual grid plotting **Likelihood (Y-axis)** vs. **Impact (X-axis)**
- **Cells** represent **overall risk severity** (color-coded: green/yellow/red)
- Helps quickly **visualize** and **communicate risk exposure**
- **Simplifies decision-making** on where to focus resources



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

THE RISK MATRIX

Measures the potential severity of the risk's consequences.

		Impact				
		Insignificant (1)	Minor (2)	Significant (3)	Major (4)	Severe (5)
Probability Measures how likely it is that a risk will occur.	Almost Certain (5)	5	10	15	20	25
	Likely (4)	4	8	12	16	20
	Moderate (3)	3	6	9	12	15
	Unlikely (2)	2	4	6	8	10
	Rarely (1)	1	2	3	4	5

LIKELIHOOD AND IMPACT ANALYSIS

- Rank risks from **highest to lowest** overall severity score
- High-severity risks** → immediate mitigation/action
- Low-severity risks** → monitor or accept
- Ensures **resources are allocated efficiently** to the most critical threats

C IMPLEMENTING & MONITORING

4 STEPS OF RISK MANAGEMENT

1. **Identify** Risk
2. **Assess** Risk
3. **Implement** the Risk Response Plan
4. **Monitor and Control** Risk Response

IMPLEMENT THE RISK RESPONSE PLAN

- The process of **executing** the **chosen risk response strategies and actions** that were planned during the risk assessment stage.
- Involves**
 - Resource Allocation
 - Assigning Responsibilities
 - Setting Timelines
 - Selecting the Right Tools

RISK RESPONSE STRATEGIES

- Avoid**
 - Eliminate the risk entirely
- Mitigate**
 - Reduce the likelihood or impact
- Transfer**
 - Shift the risk to a third party
- Accept**
 - Acknowledge and monitor without action

THE IMPLEMENTATION PROCESS

1. **Finalize** the chosen response strategy
2. **Assign** roles and responsibilities
3. **Allocate** budget and resources
4. **Set** a timeline / schedule
5. **Execute** the planned actions

6. **Document** the implementation

SUCCESSFUL IMPLEMENTATION REQUIRES:

- Clear ownership**
 - Who is accountable
- Adequate resources**
 - budget, tools, manpower
- Open communication**
 - stakeholders informed at every stage

MONITOR AND CONTROL RISK RESPONSE

- The **ongoing process** of **tracking identified risks**, reviewing the **effectiveness of response plans**, and **identifying new risks** as they emerge.
- Involves**
 - Tracking
 - Reviewing
 - Adjusting
 - Reporting

MONITORING TECHNIQUES AND TOOLS

- Regular **risk audits** and **inspections**
- Key Risk Indicators (KRIs)** and **dashboards**
- Status reports** and **team check-ins**
- Feedback loops** from stakeholders

L7: BUSINESS CONTINUITY MANAGEMENT

TOPIC OVERVIEW

- A. FOUNDATIONAL DEFINITIONS
- B. MAXIMUM TOLERABLE DOWNTIME
- C. BUSINESS IMPACT ANALYSIS
- D. PLAN REVIEW
- E. TESTING THE PLAN

A FOUNDATIONAL DEFINITIONS

BUSINESS CONTINUITY MANAGEMENT (BCM)

- An **organization-wide framework** of **policies, processes**, and **capabilities** that prepare a business to **prevent, respond** to, and **recover** from disruptive incidents

BUSINESS CONTINUITY PLAN (BCP)

- The **documented set of procedures** an organization follows to keep critical functions running **during**, and immediately **after**, a **disruption**



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

DISASTER RECOVERY (DR)

- A technical, IT-focused subset of continuity planning concerned with **restoring systems, data, and infrastructure after an outage**

KEY RECOVERY METRICS

- **Recovery Time Objective**
 - The **maximum acceptable time** to **restore** a business function after a disruption occurs.
- **Recovery Point Objective**
 - The **maximum acceptable amount of data loss**, measured as a point in time to which data must be restored
- **Maximum Tolerable Downtime**
 - The **absolute limit of disruption** a function can withstand before survival of the business is threatened.
- **Work Recovery Time**
 - The **time needed** after systems are restored to verify data and resume normal processing

MORE ESSENTIAL TERMS

- **Incident, Crisis, and Disaster**
 - **Escalating levels of severity**: an incident is a minor disruption, a crisis threatens objectives and reputation, and a disaster causes major, often prolonged, damage.
- **Resilience & Single Point of Failure (SPOF)**
 - Resilience is the ability to **absorb and adapt to disruption** without losing function; a SPOF is any single component whose failure stops the entire process
- **Continuity of Operations**
 - The **sustained delivery** of an organization's **critical services and functions** throughout a disruption, not merely their eventual restoration

B

MAXIMUM TOLERABLE DOWNTIME

MAXIMUM TOLERABLE DOWNTIME

- also called Maximum Tolerable Period of Disruption (MTPD) — is the **longest period** a **critical business function** can be **unavailable** before the consequences become unacceptable, and potentially threaten the survival of the organization itself.
- **It is not a target to aim for** — it is the outer boundary every recovery strategy must stay inside

Why it matters?

- **Anchors** every other recovery metric (RTO, RPO, WRT)
- **Differs by function** — payroll tolerates more downtime than trading
- **Drives investment priorities** and recovery strategy design

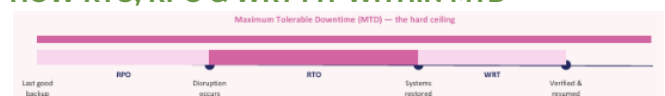
WHAT DRIVES MTD?

- **Financial Impact**
 - **Lost revenue, contractual penalties, and cash-flow strain** that accumulate the longer a function stays down
- **Reputational Damage**
 - **Erosion of customer, investor, and media trust** — damage that often outlasts the outage itself
- **Regulatory & Legal Obligations**
 - **Compliance deadlines and statutory duties** that create hard limits on acceptable disruption
- **Operational Dependencies**
 - **Downstream processes** and **contractual SLAs** with partners that fail once this function is unavailable too long

THE COST OF DOWNTIME ESCALATES OVER TIME

- Impact rarely rises in a straight line — it **accelerates**. Early hours may be **absorbed** by **buffers and goodwill**; each additional day compounds **financial, legal, and reputational** cost until it approaches the MTD ceiling
- **MTD marks the point beyond which the curve becomes unacceptable** — by definition, not by degree

HOW RTO, RPO & WRT FIT WITHIN MTD



- **RPO** looks **backward** from the disruption to set **how much data loss is tolerable**. **RTO** measures the **recovery effort** itself. **WRT** covers **verification** before normal work resumes. Together, RPO + RTO + WRT must fit comfortably inside the MTD boundary

STEPS TO DETERMINE ACCEPTABLE DOWNTIME

1. **Identify Critical Processes**
 - List the **functions** the organization cannot operate without
2. **Consult Stakeholders & Regulators**
 - Gather **input** from process owners, customers, and compliance bodies



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

3. Quantify Impact Over Time

- **Model** how **financial**, **legal**, and **reputational** harm grows hour by hour

4. Set the MTD Threshold

- Agree the **point beyond** which impact becomes **unacceptable**

5. Derive RTO & RPO Targets

- **Work backward** to set recovery objectives safely inside that ceiling

C

BUSINESS IMPACT ANALYSIS

WHAT IS BUSINESS IMPACT ANALYSIS

- A process to **identify and evaluate** the **effects of a disruption** to critical business operations.
- Key foundation of **Business Continuity** and **Disaster Recovery Planning**.
- **Answers:** "What happens to the business — financially, operationally, legally, and reputationally — if this process stops working?"
- **Different from Risk Assessment:** **Risk** asks "what could go wrong?" while **BIA** asks "what's the impact, and how quickly must we recover?"

WHY IT MATTERS?

- Identifies **mission-critical functions** vs. deferrable ones
- Quantifies **financial**, **operational**, **legal**, and **reputational** impact
- Justifies **budget** for recovery investments
- Prevents **over- or under-investing** in the wrong priorities
- May be required for **regulatory compliance**
- Builds **resilience** — helps reduce recovery time and unnecessary costs
- Aligns **business**, **IT**, and **leadership** on priorities

KEY OBJECTIVES

- Identify **critical business processes** and their dependencies — people, systems, data, and vendors involved
- Determine how **impact escalates over time**, from minor disruption to severe or unacceptable impact
- Establish clear **recovery priorities** so leadership knows which processes to prioritize
- Identify **resource requirements** for recovery — staffing, technology, facilities, and vendor support

- Surface hidden **interdependencies** and **single points of failure** across departments
- Provide a **shared understanding** across the organization of what "critical" actually means

CORE METRICS

- **RTO (Recovery Time Objective)**
 - maximum **acceptable time** a system/process can be unavailable before it must be restored
- **MTD (Maximum Tolerable Downtime)**
 - maximum **time a process can be unavailable** before the impact becomes unacceptable
- **RPO (Recovery Point Objective)**
 - maximum **acceptable amount of data loss**, measured in time
- **MBCO (Minimum Business Continuity Objective)**
 - **minimum service level** the business must maintain during a disruption

THE BIA PROCESS — STEP BY STEP

1. **Define scope** — which departments, processes, and locations are covered
2. **Identify critical business functions** through interviews, surveys, and workshops with process owners
3. **Map dependencies** — people, technology, facilities, data, and third party vendors
4. **Assess impact at 7 increasing time intervals** across financial, operational, legal, and reputational categories
5. **Assign RTO, RPO, and MTD** for each critical process
6. **Prioritize functions for recovery** based on severity and time sensitivity
7. **Document findings and validate** with stakeholders; feed results into BCP/DRP

TYPES OF IMPACT ASSESSED

- **Financial** — lost revenue, increased costs, penalties
- **Operational** — halted production, service failures, lost productivity
- **Legal/Regulatory** — compliance breaches, fines, legal obligations
- **Reputational** — loss of trust, negative media, brand damage
- **Contractual** — SLA breaches, penalties, contract termination
- **Strategic** — delayed launches, missed opportunities, competitive disadvantage



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

KEY TAKEAWAYS

- BIA turns **"what if"** scenarios into **measurable, prioritized, and actionable** information
- Provides an **analytical foundation** for effective Business Continuity and Disaster Recovery planning
- Helps **allocate limited recovery resources** to the areas that matter most
- **Not a one-time exercise** — it should be reviewed regularly as processes and priorities change
- A strong BIA helps **reduce downtime, financial loss, and reputational harm** during disruptions

COMMON TOOLS & TECHNIQUES

- **Structured interviews & workshops** — gather detailed information from department heads and process owners
- **BIA questionnaires/surveys** — collect consistent information across different business units
- **Dependency mapping** — visualize how processes, systems, people, and vendors depend on each other
- **Impact-over-time analysis** — show how the impact of a disruption increases over time
- **Criticality ranking matrices** — compare processes and determine which should be prioritized
- **BCM software** — standardize and manage BIA activities, especially in larger organizations

D PLAN REVIEW

WHY REVIEW THE PLAN?

- A continuity plan is **only accurate the day it is written**. Organizations **change, staff turn over, systems evolve**, and new threats emerge — without regular review, the plan quietly drifts out of step with reality
- **PEOPLE CHANGE** - Roles, contacts, and responsibilities move on
- **SYSTEMS CHANGE** - New platforms replace what describes
- **RISK CHANGE** - New threats emerge that earlier plans never considered

WHEN TO TRIGGER A REVIEW

- **SCHEDULED INTERVAL**
 - A **baseline review**, typically annual, regardless of whether anything else has changed

- **ORGANIZATIONAL OR TECHNOLOGY CHANGE**
 - **Restructures, mergers, new systems, or office moves** that alter dependencies
- **AFTER AN INCIDENT OR AUDIT FINDING**
 - **Real events and independent findings** are the most reliable evidence a plan needs updating

THE REVIEW PROCESS

1. **Confirm Scope & Ownership**
 - Check that named **owners** and covered **functions** are still **valid**.
2. **Validate Contacts & Dependencies**
 - **Update contact** lists, suppliers, and system dependencies.
3. **Cross-Check Against the BIA**
 - Ensure **recovery priorities** still match current **business impact**.
4. **Update Procedures**
 - **Revise steps** to **reflect** current people, systems, and processes
5. **Sign-Off & Version Control**
 - **Formally approve** and **record the plan** as the current controlled version

ROLES AND RESPONSIBILITY

- **Senior Management**
 - **Owns the plan overall** and formally approves it after review.
- **BC Manager**
 - **Coordinates** the review, **schedules** input, and **tracks** completion.
- **Department Heads**
 - **Validate** that local procedures still **reflect** how their teams actually work.
- **Internal Audit**
 - Provides **independent assurance** that the review was thorough and objective.

E TESTING THE PLAN

WHY TEST?

- **Validates Assumptions**
 - **Confirms** that the **plan's assumptions** about people, systems, and timing **actually hold up**
- **Uncovers Gaps**
 - **Surfaces missing steps, outdated contacts, and unrealistic timelines** before a real event does.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Trains Staff**
 - Builds **familiarity** and **confidence** so people know exactly what to do under pressure
- **Satisfies Compliance**
 - Demonstrates **due diligence** to regulators, auditors, and insurers.

TYPES OF EXERCISES

EXERCISE	DESCRIPTION	EFFORT	DISRUPTION RISK
Walkthrough	Team talks through the plan step by step at a desk	Low	None
Tabletop Exercise	Facilitated discussion of a simulated scenario	Medium	None
Simulation	Realistic scenario run in a test environment	High	Low
Full Interruption	Live systems actually failed over to recovery	Very High	Moderate

THE TESTING CYCLE

- **Plan** - Document procedures and recovery objectives
- **Test** - Exercise the plan under realistic conditions
- **Review** - Results Capture what worked and what did not
- **Update** - Plan Fold lessons learned back into the plan

KEY TAKEAWAYS

- **Shared terminology** (RTO, RPO, MTD, WRT) keeps every team **speaking the same language**.
- **Maximum Tolerable Downtime** is the **ceiling** every recovery target must fit beneath.
- A **Business Impact Analysis** turns **disruption into numbers**, and **numbers into priorities**.
- **Plans decay** — scheduled and trigger-based reviews keep them accurate.
- **Testing**, from **tabletop to full interruption**, proves the plan before a real event does

L8: BACKING UP DATA AND APPLICATION

TOPIC OVERVIEW

- A. TYPES OF BACKUPS
- B. PREPARATION
- C. IDENTIFICATION
- D. THE THREE-PHASE RESPONSE MODEL
 - a. Notification
 - b. Response
 - c. Recovery
- E. POST INCIDENT REVIEW
- F. DOCUMENTATION

G. REPORTING H. SUMMARY

A TYPES OF BACKUPS

BACKUP

- Backing up data means **creating copies of files and systems** so they can be **restored** if the originals are lost, damaged, or corrupted. There are **several common types** of backups, each with different tradeoffs in **speed**, **storage space**, and **recovery time**. Understanding these types helps organizations choose the right strategy for protecting their data.

1. FULL BACKUP

- slowest to create, fastest to restore, uses the most storage

2. INCREMENTAL BACKUP

- An incremental backup only **copies data that has changed since the last backup**, whether that was a full backup or another incremental backup. This makes it much **faster** and **more storage-efficient** than a full backup, but **restoring data can take longer** since multiple backup sets are needed.

3. DIFFERENTIAL BACKUP

- A differential backup **copies all data that has changed since the last full backup**, not since the last backup of any kind. Over time, differential backups **grow larger** than incremental ones, but they are **faster to restore** because only **two backup sets** are needed: the **full backup** and the **latest differential**.

4. MIRROR BACKUP

- A mirror backup creates an **exact, real-time copy of the source data**, similar to a full backup but **continuously updated**. Unlike other backup types, a mirror backup does **not keep older versions of files**. If a file is deleted from the source, it is also removed from the mirror, which can be risky if data loss goes unnoticed.

COMPARISON OF BACKUP TYPES

1. Full backup

- slowest to create, fastest to restore, uses the most storage



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

2. Incremental backup

- fastest to create, slowest to restore, uses the least storage

3. Differential backup

- moderate creation speed, faster restore than incremental, moderate storage use

4. Mirror backup

- real-time copy, no version history, fastest access but no rollback protection

B

PREPARATION

OVERVIEW

- Preparation lays the **foundation** for the entire incident response process, determining **how quickly and effectively** an organization can **react** once something actually goes wrong.
 - **Preparation = first phase** of Incident Handling
 - **Goal:** get the organization **ready** before an incident happens
 - **Reduces damage** and **response time** when an incident occurs
 - Involves **people, processes,** and **technology readiness**

POLICIES & PLANS

- Without a **documented policy** and **response plan**, teams waste critical time figuring out **who does what**. Preparation removes that guesswork before an incident ever occurs.
 - Establish an **Incident Response Policy**
 - Develop an **Incident Response Plan (IRP)**
 - Define **roles and responsibilities** (Incident Response Team)
 - Set up **communication** and **escalation procedures**

TOOLS & RESOURCES

- Having **detection tools**, an **up-to-date asset inventory**, and a **ready forensic kit** in place beforehand means the team can **act immediately** instead of scrambling to gather resources mid-crisis.
 - Deploy **security tools** (IDS/IPS, firewalls, antivirus, logging systems)
 - Maintain **updated hardware/software inventory**
 - Prepare **forensic tools** and **"jump kit"** (forensic drives, cables, checklists)
 - Ensure **backup systems** are in place and tested

TRAINING & TESTING

- Preparation isn't something done once and forgotten, it's an **ongoing cycle of training staff, running simulated drills, testing the plan,** and **updating it** based on what's learned.
 - Conduct regular **employee security awareness training**
 - Run **incident response drills/simulations** (tabletop exercises)
 - Test **communication channels** and **contact lists**
 - Review and update the **IR plan** periodically

C

IDENTIFICATION

OVERVIEW

- Identification is the stage where the team **separates true security incidents from false alarms**, determining the **scope and severity** of what's actually happening.
 - **Identification = detecting** and **confirming** that an incident occurred
 - Determine **scope, nature,** and **severity** of the event
 - **Distinguish a true incident** from a false alarm
 - **Early, accurate identification** limits damage

DETECTION SOURCES

- **Signs** of an incident **can come from many directions** at once: *automated alerts, log data, employee reports, or simply unusual behavior* in system performance.
 - **Alerts** from **IDS/IPS, antivirus,** and **SIEM tools**
 - **Log analysis** (system, network, application logs)
 - **Reports** from employees or end users
 - **Anomalies** in system/network performance

VERIFICATION STEPS

- Before any response begins, the team must **confirm the event is real**, collect **initial evidence**, **classify** how serious it is, and **document** everything as it unfolds.
 - **Confirm** the event is a **real security incident**
 - Gather **initial evidence** (timestamps, affected systems, indicators)
 - Classify the **incident type** and **severity level**



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Document** findings as they're discovered (chain of custody)

NEXT ACTIONS

- Once an incident is confirmed, the team **notifies the right people, assigns ownership, and preserves evidence**. Setting the stage for the response to move into containment.
 - **Notify** the Incident Response Team
 - **Assign** an incident handler/owner
 - **Preserve evidence** for further analysis
 - **Move to the Containment phase** once confirmed

D THE THREE-PHASE RESPONSE MODEL

THE THREE-PHASE RESPONSE MODEL

- Once an incident is detected, three coordinated phases determine how well an organization survives it.
- **Notification**
 - **Alert** the right **people**, at the right **time**, through the right **channels**.
- **Response**
 - **Contain the incident, stop** the damage, and **eliminate** its root cause.
- **Recovery**
 - **Restore systems and data**, verify integrity, and resume operations.

D1 NOTIFICATION

WHO SHOULD BE INFORMED?

Notification lists should be **prepared before an incident occurs**, not written from scratch during one.

- **Internal IT & Security Teams**
 - The incident response team, system administrators, and network/security staff who will **investigate** and **act**.
- **Management & Executives**
 - Department heads and senior leadership who need **situational awareness** and must **approve major decisions**.
- **Legal & Compliance Officers**
 - To **assess regulatory obligations**, liability exposure, and mandatory **disclosure requirements**.
- **Affected Users & Customers**
 - **Anyone** whose data, accounts, or services were **impacted**, so they can protect themselves.

- **Law Enforcement & Regulators**

- **Required** for certain incidents (e.g., data breaches, fraud) under **law** or **industry regulation**.

REPORTING & THE VALUE OF SPEED

- **Reporting the Incident**

1. **Standardized Reports**

- Use a *structured report* to detail what happened, when, affected systems, and initial impact.

2. **Defined Communication**

- Follow *pre-defined communication chains* to reach the right people first time.

3. **Audit Trail Logging**

- Log every single step with *precise timestamps and actions* taken for later review.

4. **Factual Accuracy**

- Keep *reports strictly factual and updated* as new information emerges; avoid speculation.

- **Why Timely Notification Matters**

1. **Limits the Damage**

- *Early warning* lets security teams quickly isolate the threat before it spreads further.

2. **Meets Legal Deadlines**

- Many *strict breach-notification laws* set clear windows (e.g., 72 hours) for compliance.

3. **Preserves Vital Trust**

- *Prompt, honest disclosure* protects *organizational reputation* more than delayed info.

4. **Speeds Up Recovery**

- *The sooner the right stakeholders are engaged*, the faster the recovery phase can begin.

D2 RESPONSE

CONTAINING THE INCIDENT

Containment **stops an incident from spreading** while **preserving evidence** for investigation.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

- **Isolate affected systems**
 - **Disconnect compromised devices or network** segments to stop lateral movement.
- **Disable compromised accounts**
 - **Suspend or reset credentials** that may have been exploited by the attacker.
- **Apply short-term fixes**
 - **Block malicious IPs**, close exploited ports, or apply emergency firewall rules.
- **Preserve evidence**
 - **Capture logs, memory dumps, and system states** before making further changes.

PREVENTING DAMAGE & REMOVING THE CAUSE

- **Preventing Further Damage**
 1. **Continuous Monitoring**
 - *Monitor systems continuously* for signs the incident is spreading or recurring.
 2. **Patch Vulnerabilities**
 - *Patch related vulnerabilities elsewhere* in the environment before attackers exploit them.
 3. **Segment Networks**
 - *Strengthen access controls and segment networks* to limit any future blast radius.
 4. **Staff Communication**
 - *Communicate interim safety measures* to staff and users while remediation continues.
- **Removing the Cause**
 1. **Root Cause Identification**
 - *Identify the root cause:* malware, misconfiguration, credentials, or unpatched flaw.
 2. **Malware Eradication**
 - *Eradicate malicious code, backdoors, and unauthorized accounts* left behind.
 3. **Close Vulnerabilities**
 - *Close the specific vulnerability* that allowed the incident to happen in the first place.
 4. **Eradication Verification**
 - *Verify eradication with scans and audits* before declaring the environment clean.

D3

RECOVERY

RESTORING SYSTEMS & DATA FROM BACKUPS

Recovery **brings the business back online** using **clean, verified backups** — never data that may still be compromised.

- **Identify a Clean Restore Point**
 - **Choose a backup** taken **before the incident occurred**, confirmed free of malware or tampering.
- **Rebuild on Trusted Media**
 - **Reinstall systems** from **verified, uninfected sources** rather than restoring over a compromised host.
- **Restore in Priority Order**
 - **Bring back critical business systems first**, based on the organization's recovery priorities.

TESTING SYSTEMS & RETURNING TO NORMAL

- **Testing if Systems Work Properly**
 1. **Verify Functionality**
 - *Confirm applications, services, and data are accurate and complete.*
 2. **Security Scans**
 - *Run security scans* to confirm no trace of the original threat remains.
 3. **Performance Check**
 - *Check performance under normal load* before declaring systems production-ready.
 4. **Obtain Sign-Off**
 - *Get sign-off from IT, security, and business owners* before going live.
- **Returning to Normal Operations**
 1. **Gradual Rollout**
 - *Bring systems back online gradually*, monitoring closely for renewed issues.
 2. **Notify Stakeholders**
 - *Inform stakeholders and users* that services are restored and safe to use.
 3. **Resume Monitoring**
 - *Resume normal monitoring routines* rather than emergency-level watchfulness.
 4. **Lessons Learned**
 - *Document lessons learned and update the incident response plan* accordingly.



INFORMATION ASSURANCE AND SECURITY 2

ITAS311-T

3RD YEAR 1ST SEM – PROF. POPS MADRIAGA – MONDAY | 8:00AM-11:45AM

E POST INCIDENT REVIEW

POST INCIDENT REVIEW

- What happened, and when
- Were the documented procedures followed, and were they adequate?
- What slowed the recovery down?
- What do we do differently next time?

FIND THE REAL CAUSE, NOT JUST THE SYMPTOM

- **Symptom:** "The server went down."
Real cause: nobody was watching the disk space, and nobody had ever tested a restore.
An easy method: keep asking "why?" until you reach something you can actually fix. This is called the 5 Whys.
- **Check if the backup really worked**
This is where the restore gets judged. Two questions:
 - **How much data** did we lose, and could we afford to lose that much? (This is the **RPO**.)
 - **How long** were we down, and was that fast enough? (This is the **RTO**.)
 - A backup that turns out damaged or three weeks old is itself a finding.
- **Every finding needs a person in charge and a due date.**
 - Then update the response plan, the backup policy, and the step-by-step guides.
 - **Numbers to track:** how long it took to **notice the problem** (MTTD), how long it took to fix it (MTTR), total downtime, data lost, and cost.

F DOCUMENTATION

DOCUMENTATION

- Documentation **starts** the moment you **detect the incident**
- **You do not write it at the end.**
 - It is a **running log**. Responders **write down each step**, with the **time**, while they are still working on the problem.

WHAT TO WRITE DOWN:

- **Incident ID:** one number that connects all the records together
- **Discovery:** when it was found, how it was found, and who found it
- **Scope:** which systems, applications, and data were affected
- **Severity:** how serious it was rated, and who rated it

- **Actions:** every step taken, in order, with the exact time
- **Notifications:** who was told, when, and through what channel
- **Evidence:** copies of logs, file checksums, and a record of who handled them
- **Backup used:** which backup was restored, its date, and whether it was tested
- **Write facts only. Never write guesses.**
 - The **log is evidence**. It can be used in court, in an insurance claim, or in a government audit. Keep access restricted, and keep the log for as long as your policy requires.

G REPORTING

ONE INCIDENT, FIVE DIFFERENT READERS

- **Technical team:** the full timeline, the signs of the attack, the real cause, and the fixes still to be done
- **Management:** a short summary of 1 to 2 pages. Cost, downtime, business impact, and what the team needs to stop it from happening again
- **Legal team and government regulator:** the official breach notice, filed before the legal deadline
- **Affected users:** plain language. What happened, what data of theirs was exposed, and what they should do now
- **Law enforcement:** only when a crime was committed, such as fraud, extortion, or theft of data

WHAT GOES INSIDE THE WRITTEN REPORT

- **Impact assessment**
 - is the **section managers read twice**. It is how you **justify the budget** for the fixes you are asking for.
- 1. **Executive summary:** written last, read first
- 2. **Incident overview:** what it was, and how serious
- 3. **Timeline:** from detection to closing, with times
- 4. **Systems and data affected:** what was hit, and how much
- 5. **Root cause:** the real reason, not the symptom
- 6. **Response and recovery:** what the team did, including which backup was used
- 7. **Impact assessment:** money lost, downtime, data lost, and damage to reputation
- 8. **Lessons learned:** what worked, and what did not
- 9. **Recommendations:** each one with a person in charge and a due date



10. **Appendices:** logs, screenshots, and other evidence

REQUIRED BY LAW

- **Republic Act 10173**, the **Data Privacy Act** of 2012. NPC Circular 16-03.
 - **72 hours:** notify the **National Privacy Commission** and the people whose data was exposed. The clock starts when you know, or have good reason to believe, that a breach happened. It does not start when your investigation is finished.
 - **5 days:** submit the **full breach report**, counted from the day you discovered the breach. Asking the NPC for an exemption does not stop the clock.
- The notice must **state what happened**, what **personal data** was involved, **what you did** to reduce the harm, and **who to contact**, such as the **Data Protection Officer**.
- This does get **enforced**. H&M Philippines was ordered by the NPC to explain why it missed the 72-hour deadline after a payment card incident in 2018.

G SUMMARY

KEY TAKEAWAYS

Follow up, Documentation, Reporting

- **Follow-up** turns an outage into an improvement.
 - Find the **real cause**, not the symptom. Give every fix a person in charge and a due date. Confirm the backup **met the RPO and the RTO**.
- **Documentation** is written during the incident, not after it.
 - It is a **running log of facts, with times**. It counts as **evidence**, so keep it factual and keep access restricted.
- **Reporting** changes with the reader.
 - Five audiences, five levels of detail. When personal data is involved, the deadline is 72 hours by law.